

TFM AquaControl S.A. — Registro de laboratorio

Fase 5 — Remediación: segmentación real y conducto único controlado

Fecha: 27 de julio de 2026 **Laboratorio:** independiente del deficiente (Fases 2-4), no lo sustituye

Componentes: openplc-corregido, conducto (proxy socat), kali-corregido (nicolaka/netshoot)

1. Objetivo

Implementar y probar empíricamente, sobre un segundo laboratorio Docker independiente, la arquitectura corregida propuesta en la sección de medidas de protección (diagrama con DMZ y zonas Purdue): que un atacante situado en la red IT ya no pueda alcanzar directamente el PLC en la red OT, y que el único camino posible sea un conducto controlado que permite exclusivamente el tráfico legítimo.

2. Decisión de diseño: por qué un proxy de aplicación y no un firewall con enrutamiento

Se valoraron dos aproximaciones:

1. **Firewall con iptables/ip_forward entre red_it y red_ot.** Técnicamente correcto, pero requiere reglas de enrutamiento a nivel de kernel dentro de un contenedor dual-homed, además de rutas estáticas en los contenedores peer. Es frágil y depende de configuración de kernel del host — justo el tipo de complejidad que los tutores pidieron evitar por riesgo de que no se reproduzca en otro ordenador.
2. **Proxy de aplicación (socat) dual-homed.** Un contenedor conectado a ambas redes que escucha en su interfaz de red_it y reenvía únicamente el puerto explícitamente autorizado hacia red_ot. No requiere ip_forward ni rutas adicionales: el reenvío ocurre en espacio de usuario, dentro del propio proceso. Es la opción elegida.

Este diseño materializa el concepto de **conducto único controlado** de IEC 62443: solo se permite el tráfico de gestión web de OpenPLC (puerto 8080); el puerto Modbus (502) —el vector de ataque explotado en la Fase 3— no se reenvía en absoluto.

3. Incidencia — solapamiento de subredes Docker

Al primer intento de `docker compose up`, Docker rechazó la creación de la red:

```
Error response from daemon: invalid pool request: Pool overlaps with other one on this address space
```

Causa: el laboratorio deficiente (Fases 2-4) seguía en ejecución con las subredes 172.20.0.0/24 (IT) y 172.21.0.0/24 (OT). Docker no permite dos redes distintas con rangos de IP solapados en el mismo host.

Solución: se reasignaron las subredes del laboratorio corregido a 172.30.0.0/24 (IT) y 172.31.0.0/24 (OT), evitando cualquier colisión y permitiendo tener ambos laboratorios — el deficiente y el corregido — corriendo simultáneamente para comparación directa.

4. Despliegue

```
cd arquitectura-corregida
docker compose up -d --build
```

Los tres servicios quedaron activos:

```
conducto          Up
kali-corregido     Up
openplc-corregido  Up (502/tcp, 8080/tcp – sin publicar al host)
```

Nótese que, a diferencia del laboratorio deficiente, aquí `openplc-corregido` no publica ningún puerto al host: el único acceso previsto es a través del conducto, ni siquiera desde la propia máquina anfitriona.

5. Pruebas de verificación

5.1 Acceso directo Kali → OpenPLC (debe fallar)

```
docker exec -it kali-corregido nmap -p 502,8080 -Pn 172.31.0.10
```

```
PORT      STATE  SERVICE
502/tcp   filtered mbap
8080/tcp   filtered http-proxy
```

Resultado: correcto. `filtered` indica que no existe ninguna ruta de red entre `red_it` y `red_ot` — los paquetes se pierden sin respuesta. Kali no tiene interfaz alguna en `red_ot`, así que ni siquiera puede confirmar con certeza que el host exista.

5.2 Acceso legítimo vía el conducto (debe funcionar)

```
docker exec -it kali-corregido curl -I http://172.30.0.20:8080
```

```
HTTP/1.0 302 FOUND
Location: http://172.30.0.20:8080/login
Server: Werkzeug/0.16.0 Python/2.7.17
```

Resultado: correcto. El conducto reenvía el tráfico de gestión web hacia OpenPLC con normalidad — el mantenimiento remoto legítimo no se ve afectado por la segmentación.

5.3 Intento de Modbus vía el conducto (debe fallar)

```
docker exec -it kali-corregido nc -zv -w 3 172.30.0.20 502
```

```
nc: connect to 172.30.0.20 port 502 (tcp) failed: Connection refused
```

Resultado: correcto. El conducto no tiene ningún listener en el puerto 502; el vector de ataque demostrado en la Fase 3 (escritura Modbus no autenticada) queda cerrado incluso para un atacante que ya esté dentro de la red IT.

6. Tabla comparativa — antes / después

Prueba	Laboratorio deficiente (Fase 2-3)	Laboratorio corregido (Fase 5)
Kali alcanza OpenPLC directamente	Sí (Kali dual-homed en IT+OT)	No (filtered, sin ruta)
Puerto 502 accesible desde IT	Sí, sin autenticación	No, ni siquiera vía el conducto
Gestión web de OpenPLC accesible	Sí, directa	Sí, únicamente vía el conducto controlado
Escritura Modbus no autorizada (T0855)	Posible (demostrada en Fase 3)	No posible desde la red IT

7. Relación con el marco normativo de la memoria

Este laboratorio corregido materializa directamente:

- **IEC 62443** — el conducto es la implementación literal de un "conducto" entre zonas de seguridad (Zona 3 IT <-> Zona 1-2 OT), permitiendo únicamente el tráfico explícitamente autorizado.
- **Modelo Purdue** — separa físicamente (a nivel de red Docker) la zona corporativa de la zona de control, con un único punto de cruce auditable.
- **NIS2 (Art. 21)** — demuestra una medida técnica concreta de gestión de riesgos aplicada al vector de ataque identificado en la Fase 3.